



Part 11 & ALCOA++ Implemented Capabilities

Data-integrity & electronic-records controls already built into the Andrei Investigation Report platform

Prepared for M.J. Biopharm – IT

21 CFR Part 11

ALCOA++

WHAT THIS COVERS

Scope of this review

Mapped against the **21 CFR Part 11 / ALCOA++ Vendor Design Spec** and the **MJ Software Checkpoints** list. This deck shows the **software design features already implemented** in Andrei — not procedural or validation activities.

✔ **Electronic records**

Reports, sections, comments and evaluations persisted with full history.

✔ **Electronic signatures**

Password-bound submit / review / approve actions (Part 11 Subpart C).

✔ **Audit & access**

Tamper-evident audit trail and role-based access control.



— AT A GLANCE

Control areas live today

RBAC

Access control

Unique IDs, roles, admin-managed accounts, lockout.

• IMPLEMENTED

Hash-chained

Audit trail

Append-only, SHA-256 linked, exportable, non-disableable.

• IMPLEMENTED

Re-auth

E-signatures

Password re-entry at the moment of signing.

• IMPLEMENTED

script

Password policy

Complexity, expiry, history, masked entry.

• IMPLEMENTED

Versioned

Record history

Prior values retained; never overwritten.

• IMPLEMENTED

TLS

Encryption

In transit and at rest (cloud-hosted).

• IMPLEMENTED

Attributable by design

§11.10(d) §11.100 §11.300 ALCOA++: Attributable

User management

- ✓ **Unique user IDs** — duplicate accounts rejected at creation.
- ✓ **ID + password** login; no shared or generic logins.
- ✓ **RBAC** — Engineer, Manager, Admin — enforced on every route.
- ✓ **Admin-only** account creation, role changes, resets & revocation.
- ✓ **Access revocation** supported; config restricted to administrators.

Password & session policy

Complexity
Min 8 chars, letter + number + special. Masked; no autosave.

Reuse history
Last 3 passwords blocked from reuse.

First login
Forced password change; expired passwords gated.

Expiry
Configurable, default 90 days, with advance warnings.

Lockout
Locks after consecutive failed attempts (default 3).

Auto-logout
Inactivity sign-out (default 10 min). Hashing: **scrypt**.

AUDIT TRAIL

Secure & tamper-evident

§11.10(e) · Attributable · Contemporaneous · Complete

Automatic logging

Every create / modify / delete on GxP data is logged automatically and immediately.

Who, when, what

User ID, role, system timestamp, and old & new value for each action.

Append-only

UPDATE/DELETE blocked at the database — even for administrators.

Non-disableable

Audit generation cannot be turned off by any role, including admin.

Exportable

Full trail export on demand as CSV or PDF, with chain verification status.

SHA-256 hash chain

Each entry cryptographically links to the previous — any edit breaks the chain.



Records you can trust

§11.10(e) §11.50 §11.200 Original · Complete · Attributable

Version history & integrity

- ✓ **Section versioning** — every save stored as snapshot or diff; full history reconstructable.
- ✓ **Previous values retained** electronically — original data never overwritten.
- ✓ **Checkpoint before signing** — content frozen at the moment of each signature.
- ✓ **Status-based edit locks** on submitted and approved reports.

Signed, attributable actions

Re-authentication

Password re-entered at signing — not satisfied by an active session alone.

Manifestation

Signer name, ID, date/time and meaning (submission / approval / rejection).

Workflow signatures

Submit, return-for-feedback and approve are all signed events.

Carried into export

Signature records appended to exported DOCX as a Part 11 block.

DATA SECURITY

Encryption & hosting

§11.30 Original · Accurate (open systems)

In transit

HTTPS/TLS everywhere; database connections require TLS (`sslmode=require`).

At rest

Provider-managed encryption at rest on the managed Postgres backend.

Credentials

Passwords stored as salted **scrypt** hashes; audit hashes via pgcrypto SHA-256.

ALCOA++

How each attribute is met

Attributable Unique IDs, RBAC, signed actions	Legible In-app view + DOCX/PDF export	Contemporaneous Immediate, system-timestamped audit
Original Source DOCX + version history kept	Accurate Old/new values, AI evaluation checks	Complete All actions retained, append-only
Consistent Sequenced, status-driven workflow	Enduring Durable managed Postgres storage	Available Retrievable & exportable on demand



— BOUNDARIES & NEXT STEPS

What we don't cover — and what's next

A quick answer to two questions IT and QA often ask: “Does this apply to us?”
and “What's still missing?”

• NOT APPLICABLE TO ANDREI

Some checklist items are written for **factory equipment software** (PLCs, instruments, alarms). Andrei is a **web report editor** — it doesn't connect to shop-floor devices, so these clauses don't apply:

- Instrument / PLC input–output lists
- Validating data from connected devices
- Equipment alarm logs & comm-failure alerts
- Antivirus file-exclusion lists
- IQ/OQ/PQ validation (*that's a separate validation project, not a software feature*)

• PLANNED ENHANCEMENTS

Features we're aware are still missing and intend to add:

- **Reason for change** — prompt users to say *why* they edited a record
- **Stricter workflow rules** — block out-of-order actions (e.g. approve before review); prevent the same person from reviewing and approving
- **Signature tied to version** — prove exactly which report content was signed
- **Retention settings** — configurable archive periods and a single combined export (PDF + machine-readable format)



Andrei

**Built for compliance,
ready for review.**

Better Documents. Better Outcomes.

Questions & clause-level walkthrough available on request